Stopping spam at the endpoint

Six server-side measures for `/submit`, in build order. All of it ships inside XoFormPro — no HTML changes on laili.co.uk or any other site using the service.

ENDPOINT	CLIENT SCRIPT	PROTECTION TODAY
xoformpro.xeniaone.com/submit	/forms.js — centrally hosted	honeypot fields only

PAYLOAD FORMATS

JSON, multipart (with files)

WHY THE HONEYPOT FAILS

> Every site embeds its `access_key` and the `/submit` URL in page source. Scrapers harvest both, then POST directly with curl. They never load the page, never render the form, never see `botcheck` or `_gotcha` — they just send the required fields.
>
> A honeypot only catches bots that parse and fill a rendered form. Anything aimed at the endpoint walks straight past it, which is what's happening now.
>
> **Rotating access keys will not help.** The new key is public the moment the page ships. Every measure below assumes the key is world-readable and defends the endpoint instead.

THE SIX MEASURES

01 Origin allowlist, per access key

01

Origin allowlist, per access key

BIGGEST SINGLE WIN | ~HALF A DAY | SERVER ONLY

Store a list of permitted hosts against each key. Reject any submission whose `Origin` (falling back to `Referer`) isn't on it. Browsers always send one of these on a cross-origin POST; curl sends neither unless told to, and most spam tooling doesn't bother.

Match on registrable domain plus subdomain, ignore scheme and port, and treat a missing header as a fail once the key is in enforce mode.

```
key c1695533-…  →  allowed_origins: ["laili.co.uk", "www.laili.co.uk"]

origin = header("Origin") or host_of(header("Referer"))
if key.origin_mode == "enforce" and origin not in key.allowed_origins:
    log_block(key, "origin", origin)
    return 403
```

02

Rate limits

STOPS FLOODS | ~2 HOURS | SERVER ONLY

Two independent counters in Redis or equivalent. The per-IP limit stops one bot hammering; the per-key daily cap is a circuit breaker so a distributed run can't dump thousands of mails overnight before anyone notices.

Defaults suit a low-volume enquiry form — make both per-key overridable for busier sites.

```
ip_hourly    3     per (ip, key)     → 429
ip_daily     10    per (ip, key)     → 429
key_daily    200   per key           → alert + pause key

# also: identical (email, message) within 24h → silent drop
```

03

Content scoring, with quarantine

CATCHES THE REST | ~1 DAY | SERVER ONLY

Score each submission on cheap signals and act on the total. Quarantine rather than delete — hold suspect entries in the dashboard for a fortnight so a real enquiry is never lost silently. Weights below are a starting point; tune

them from real logged data.

Return the normal `{"success": true}` body on a silent drop. If blocked submissions get a distinct error, spammers tune against it.

```
+4  URL or HTML anchor in a name field
+3  more than 2 URLs in message
+3  Cyrillic / CJK in a name field on a Latin-script site
+3  BBCode ([url=, [link]) anywhere
+2  spam vocabulary (seo, backlink, crypto, casino, loan…)
+2  message is all-caps or has no spaces over 40 chars
+2  email domain on a disposable-mailbox list
+1  no phone, no message, generic name pattern

score ≥ 6  → silent drop, logged
score 3–5  → quarantine, visible in dashboard
score < 3  → deliver
```

04

Signed form token

~1 DAY | TOUCHES FORMS.JS

Prove the submission came from a real page load. On `GET /form-token?key=…` return an HMAC of `{key, origin, issued_at, nonce}`. `forms.js` fetches one on page load and attaches it as a hidden field; the server verifies signature, origin match, age, and single use.

Reject anything under 3 seconds old (nobody types a real enquiry that fast) or over 2 hours, and burn the nonce on use so payloads can't be replayed.

```
GET  /form-token?key=…   → { token, expires_at }
POST /submit             → field _xfp_token

verify: hmac ok · origin matches issuing origin
      · 3s ≤ age ≤ 2h · nonce unused → burn it
```

05

Cloudflare Turnstile

THE DURABLE ANSWER | ~1 DAY | TOUCHES FORMS.JS

The only measure that survives a determined spammer who spoofs headers and drives a real browser. Free, and unlike reCAPTCHA it's normally invisible — no puzzle, no lost enquiries.

invisible — no puzzle, no lost enquiries.

Have `forms.js` inject the widget automatically into any form whose key has Turnstile enabled, so sites need no markup change. Verify `cf-turnstile-response` against Cloudflare's `siteverify` before accepting, and pass the visitor IP so Cloudflare can score it.

```
# forms.js, when key.turnstile == true
inject <div class="cf-turnstile" data-sitekey="…"> above submit

# server
POST https://challenges.cloudflare.com/turnstile/v0/siteverify
     { secret, response: body["cf-turnstile-response"], remoteip }
→ success:false  ⇒  403
```

06

Monitor mode and a blocks log

BUILD THIS FIRST | ~HALF A DAY | SERVER ONLY

Not a filter — the instrument that makes the other five safe to turn on. Every check runs in one of three modes per key: `off`, `monitor` (evaluate and log, always deliver), `enforce`.

Run each new check in monitor for a week and read the log before enforcing. That is how you find out that a genuine buyer submits from a domain nobody remembered to allowlist, rather than finding out from an angry client.

```
log per submission: key · origin · ip · check · verdict
                    score · mode · delivered?

dashboard: blocks/day by check, quarantine queue,
           "would have blocked" count while in monitor
```

BUILD ORDER

Phases 1 and 2 need nothing from the browser, so they're deployable without touching a single site. Expect them to remove most of the current volume on their own.

```
PHASE 1 — WEEK ONE
```

PHASE 1 · WEEK ONE

Instrument, then allowlist

Measure 06, then 01, 02 and 03 in monitor mode. Read a week of logs.

PHASE 2 · WEEK TWO

Enforce

Flip 01, 02 and 03 to enforce for laili.co.uk. Watch the quarantine queue daily for the first few days.

PHASE 3 · WHEN NEEDED

Token and Turnstile

Measures 04 and 05 through `forms.js`. Hold these back unless phases 1–2 leave residual spam — they're the answer to a spammer who adapts, not to today's volume.

PER-KEY CONFIGURATION

Everything is per access key, so one site's settings can never break another's. Defaults are chosen so existing keys behave exactly as they do today until someone opts them in.

FIELD	DEFAULT	PURPOSE
`allowed_origins`	`[]`	Hosts permitted to submit with this key
`origin_mode`	`monitor`	off | monitor | enforce
`rate_ip_hourly`	`3`	Submissions per IP per hour
`rate_ip_daily`	`10`	Submissions per IP per day
`rate_key_daily`	`200`	Circuit breaker; alerts and pauses the key
`score_drop_at`	`6`	Silent drop threshold
`score_hold_at`	`3`	Quarantine threshold
`quarantine_days`	`14`	Retention before purge
`require_token`	`false`	Enforce measure 04
`turnstile`	`false`	Inject widget and verify

`turnstile_secret`	`null`	Cloudflare secret key
`notify_email`	`null`	Where the daily blocked-count summary goes

> **One thing not to break.** Laili's forms carry a real `action` and `method`, so if `forms.js` ever fails to load the browser posts natively. Measures 01–03 handle that fine — the browser still sends `Origin`. Measures 04 and 05 would reject it, which is why both default to `false` and are opted into per key. Any older integration that posts without `forms.js` keeps working untouched.

TWO ANSWERS

Does laili.co.uk need any change?

No. Not one line. Measures 01, 02, 03 and 06 are entirely server-side. Measures 04 and 05 need browser-side code, but that lives in `forms.js`, which is served from `xoformpro.xeniaone.com` and already loaded by both pages — so it deploys itself. The site's HTML stays exactly as it is.

Do other sites on XoFormPro get this too?

Yes, automatically. Both halves of the system are central: `/submit` is one shared endpoint, and `forms.js` is one shared script every site pulls at page load. Build it once and every current and future site is covered on their next page view.

The only per-site work is filling in `allowed_origins` for each key and flipping that key from monitor to enforce — a dashboard task, not a deployment. That is also the safety valve: the rollout is per key, so you can prove it on laili.co.uk before it touches anyone else's forms.
